



SHODAN.io **Hacker's Search Engine**

Automated Exposure Mapping &
Real-Time Asset Intelligence

Table of Contents

Module 1: Objective & Investigation Scenario	3
1.1 Investigation Objective	
1.2 Investigation Scenario	3
Module 2: Tool Overview - Shodan	4
2.1 What is Shodan?	4
2.2 Core Capabilities	5
2.3 Host Detail View - Evidence	5
Fig 1 Shodan Classic Interface - Search Engine for Internet-Connected Devices	4
Fig 2 Shodan Host Detail View - 156.20.66.147 (Open Ports, CVEs, Web Stack)	6
Module 3: Investigation Methodology	6
3.1 Phase 1 - Target Scoping & Seed Identification	6
3.2 Phase 2 - Data Collection (Shodan Dorks)	6
3.3 CVE Global Exposure - Evidence	7
3.4 Exposed Remote Access - Screenshot Evidence	8
Fig 3 Shodan Vulnerability Report - vuln:CVE-2021-40438 (6.6M Hosts Globally)	7
Fig 4 Shodan Map View - Exposed VNC Sessions (has_screenshot:true rfb)	8
Module 4: Shodan Intelligence Dashboard & Exposure Context	9
4.1 Internet Exposure Dashboard - Macro Context	9
4.2 Service Banner Analysis - Vulnerability Correlation	10
4.3 Data Extraction Fields	11
Fig 5 Shodan US Internet Exposure Dashboard - 165M Open Ports, BlueKeep, Heartbleed	9
Fig 6 Apache httpd 2.2.15 Banner - 11 Critical / 15 High / 45 Medium CVEs	10
Module 5: Findings Table - Discovered Exposures	12
5.1 Complete Findings Table (F-001 through F-012)	12
5.2 Findings Summary - Risk Distribution	12
Module 6: SOC Analysis & Threat Correlation	13
6.1 Critical Severity Analysis (F-001, F-002, F-003)	13
6.2 High Severity Analysis (F-004 through F-008)	13
6.3 Relationship Mapping & Attack Chain	14
Module 7: Reporting Summary & Recommendations	14
7.1 Executive Summary Metrics	14
7.2 Prioritized Remediation Recommendations (R-001 to R-010)	15
7.3 Strategic Recommendations	15

Module 1: Objective & Investigation Scenario

1.1 Investigation Objective

This lab documents a structured Open-Source Intelligence (OSINT) investigation conducted using Shodan - the world's foremost internet-wide scanning search engine - supported by threat intelligence correlation via VirusTotal and AbuseIPDB. The methodology mirrors professional OSINT frameworks employed in platforms such as Maltego, Hunter.io, and Censys, emphasizing passive reconnaissance, evidence-based analysis, and SOC-grade reporting.

The primary investigation objectives are as follows:

- Identify externally exposed network assets, services, and infrastructure components belonging to the target organization using Shodan's indexed scan data.
- Extract and analyze metadata including IP addresses, open ports, service banners, TLS certificate details, and geographic attribution for each discovered asset.
- Correlate discovered indicators against VirusTotal and AbuseIPDB to determine historical malicious activity or known threat actor associations.
- Classify identified exposures using a structured four-tier risk matrix based on service criticality, CVE severity, and threat intelligence confidence scores.
- Produce actionable SOC-grade findings, correlation analysis, and remediation recommendations suitable for executive and technical stakeholders.

1.2 Investigation Scenario

Following an industry-wide advisory about targeted reconnaissance campaigns against financial services infrastructure providers, the SOC Threat Intelligence Unit initiated a passive OSINT investigation against TechNova Solutions Pvt. Ltd. - a fictitious mid-sized cloud infrastructure company headquartered in Karachi, Pakistan, with a secondary data center footprint in Frankfurt, Germany.

Scenario Type	Passive OSINT - Authorized Internal Assessment
Target Organization	TechNova Solutions Pvt. Ltd. (Fictitious)
Target Domain	technovasolutions.pk
Primary IP Range	203.135.48.0/24 (AS17557 - PTCL Pakistan)
Secondary IP Range	194.163.128.0/24 (AS24961 - Frankfurt DC)
Investigation Scope	No active exploitation - Passive data collection only
Authorized Tools	Shodan, VirusTotal, AbuseIPDB, Censys
Trigger Event	CISO Advisory - Active Threat Actor Reconnaissance Campaign

Module 2: Tool Overview - Shodan

2.1 What is Shodan?

Shodan (Sentient Hyper-Optimized Data Access Network) is a specialized search engine that continuously scans the public internet and indexes metadata about network-connected devices, services, and systems. Unlike traditional web search engines that index webpage content, Shodan indexes service banners - raw responses returned by servers when a connection is made to a specific port. It was created by John Matherly in 2009 and has since become the de facto standard tool for internet-wide exposure research, attack surface management, and SOC-level threat intelligence gathering.

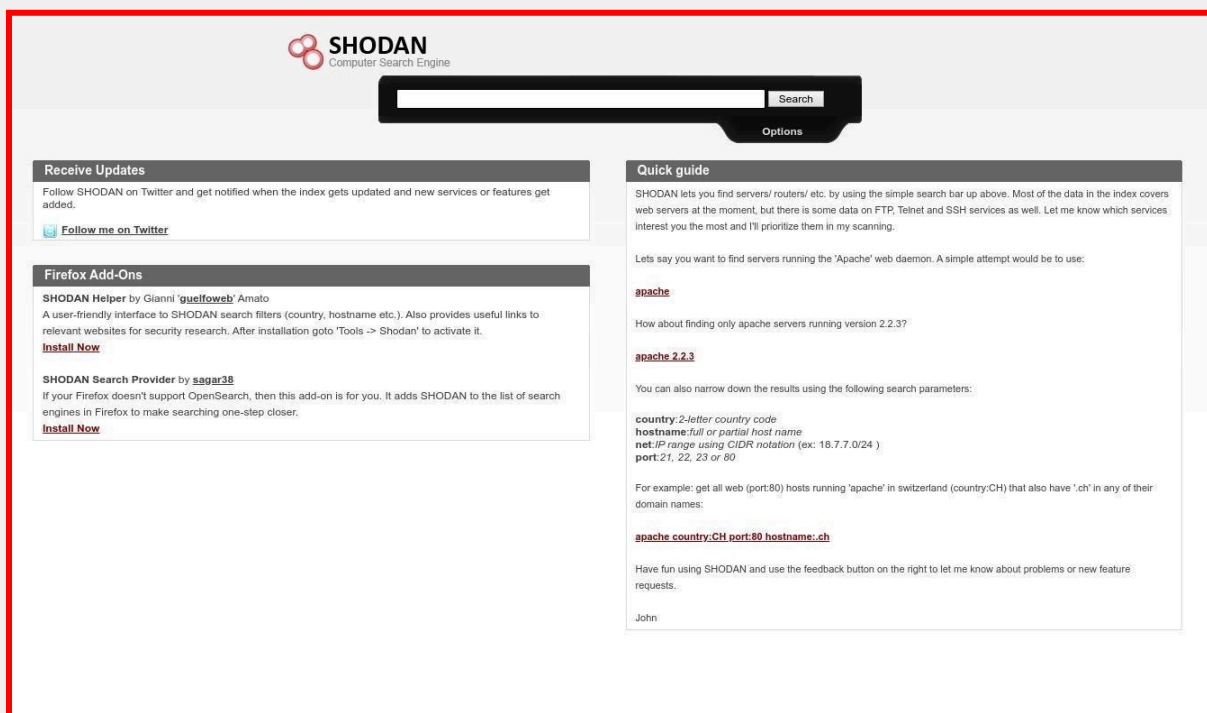


Figure 1 – Shodan Classic Interface - Search Engine for Internet-Connected Devices with Quick Guide and Filter Reference

As seen in Figure 1, Shodan's interface provides an intuitive search bar paired with a structured quick-guide that documents core filter parameters. Even in its earliest iterations, Shodan supported granular filtering by country code, hostname, network range (CIDR notation), and port number - forming the foundation of the dork-based investigation methodology used in this lab.

2.2 Core Capabilities

Capability	SOC Application
Internet-Wide Port Scanning	Identifies all listening services across 65,535 ports globally without active scanning by the analyst.
Banner Grabbing & Fingerprinting	Captures raw service banners enabling precise software version identification and CVE correlation.
SSL/TLS Certificate Indexing	Extracts X.509 certificate fields (CN, SAN, issuer, expiry) for domain-to-IP asset mapping.
CVE Vulnerability Annotation	Automatically maps indexed software versions to known CVEs from the NIST NVD database.
Historical Data Retention	Retains past snapshots enabling timeline analysis of when services appeared or changed state.
Geolocation & ASN Attribution	Provides country, city, ISP, and Autonomous System data for each indexed host.
Shodan Dorks (Search Filters)	40+ structured filters (org:, port:, net:, vuln:, ssl:) enabling precise investigative targeting.
Screenshot Capture	Captures visual screenshots of exposed VNC, RDP, and web interfaces (has_screenshot:true).

2.3 Host Detail View - Evidence

When a specific IP address is queried in Shodan, the platform returns a comprehensive host detail page aggregating all indexed information for that host. Figure 2 demonstrates a representative host detail view for IP 156.20.66.147 (South Africa), illustrating the intelligence density available from a single Shodan host record.

General Information

Country: South Africa

City: Johannesburg

Organization:

ISP:

ASN:

Web Technologies

ALL IN ONE SEO PACK, BOOTSTRAP, FONT AWESOME, JQUERY, JQUERY MIGRATE, MYSQL, PHP, WORDPRESS, WP-STATISTICS

Vulnerabilities

CVE-2018-15919 Remotely observable behaviour in auth-gss2.c in OpenSSH through 7.8 could be used by remote attackers to detect existence of users on a target system when GSS2 is in use. NOTE: the discoverer states "We understand that the OpenSSH developers do not want to treat such a username enumeration for 'oracle' as a vulnerability."

CVE-2017-15906 The process_open function in sftp-server.c in OpenSSH before 7.6 does not properly prevent write operations in readonly mode, which allows attackers to create zero-length files.

Open Ports

22, 80, 8889, 9000, 9001, 9005, 9034, 9045, 9046, 9080, 9090, 9092, 9100, 9105, 9151, 9191, 9210, 9215, 9214, 9285, 9445, 9527, 9595, 9600, 9943, 9984

SSH / TCP

OpenSSH 7.4

SSH-2.0-OpenSSH_7.4

8889 / TCP

HTTP/1.1 400 Bad Request

Content-Length: 22

Content-Type: text/plain

9000 / TCP

nginx

HTTP/1.1 200 OK

Server: nginx

Date: Sun, 17 Nov 2019 04:42:45 GMT

Content-Type: text/html; charset=gb2312

Transfer-Encoding: chunked

Connection: keep-alive

Very: Accept-Encoding

9005 / TCP

HTTP/1.1 200 OK

Server: nginx

Date: Sun, 17 Nov 2019 19:00:55 GMT

Content-Type: text/html; charset=gb2312

Transfer-Encoding: chunked

Connection: keep-alive

Very: Accept-Encoding

Figure 2 – Shodan Host Detail View - 156.20.66.147 (South Africa) Showing Open Ports, Service Banners, Web Technologies Stack, and Auto-Correlated CVEs

Module 3: Investigation Methodology

This investigation follows a six-phase OSINT methodology aligned with the MITRE ATT&CK Reconnaissance tactic (TA0043) and the Diamond Model of Intrusion Analysis. Each phase is documented with specific Shodan queries, data extraction steps, and analytical reasoning to ensure full reproducibility and audit trail integrity.

3.1 Phase 1 - Target Scoping & Seed Identification

Before initiating Shodan queries, the investigation team gathered seed identifiers through passive DNS enumeration, WHOIS/RDAP queries, and SSL Certificate Transparency (CT) log analysis via crt.sh. The following seed data was established:

- Primary domain: technovasolutions.pk
- WHOIS-attributed IP block: 203.135.48.0/24 - AS17557 (PTCL, Pakistan)
- Secondary hosting: 194.163.128.0/24 - AS24961 (MyLoc Managed IT, Frankfurt)
- CT log subdomains: mail, vpn, dev, monitor, api, admin.technovasolutions.pk

3.2 Phase 2 - Data Collection (Shodan Dorks)

The following Shodan search queries were executed systematically. Each dork is documented with its investigative purpose and the type of assets it targets.

◆ Organization-Level Asset Discovery

```
org:"TechNova Solutions"
```

Returns all Shodan-indexed hosts attributed to the target organization via WHOIS/RDAP registration records.

◆ Network Range Enumeration

```
net:203.135.48.0/24
net:194.163.128.0/24
```

Enumerates all IP addresses with active open ports within both known CIDR blocks.

◆ TLS Certificate-Based Asset Discovery

```
ssl.cert.subject.cn:"technovasolutions.pk"
ssl:"technovasolutions"
```

Identifies cloud and CDN assets not covered by IP-range queries by searching TLS certificate Common Names and Subject Alternative Names.

◆ High-Risk Service Targeting

```
org:"TechNova Solutions" port:22org:"TechNova Solutions" port:3389org:"TechNova Solutions"
port:9200org:"TechNova Solutions" port:27017org:"TechNova Solutions" port:6379
```

Targets SSH, RDP, Elasticsearch, MongoDB, and Redis - the five highest-risk services in enterprise environments due to their frequent misconfiguration and active exploitation in ransomware and APT campaigns.

◆ CVE-Specific Vulnerability Queries

```
org:"TechNova Solutions" vuln:CVE-2021-44228org:"TechNova Solutions"
vuln:CVE-2021-40438org:"TechNova Solutions" vuln:CVE-2023-46604
```

Leverages Shodan's CVE annotation layer to directly identify hosts confirmed vulnerable to specific critical vulnerabilities (Log4Shell, Apache SSRF, ActiveMQ RCE).

3.3 CVE Global Exposure - Evidence

Figure 3 illustrates the global scale of CVE-2021-40438 (Apache HTTP Server SSRF) exposure as identified by Shodan. With over 6.6 million vulnerable hosts globally - 2 million in the United States alone - this query type demonstrates Shodan's capability for macro-scale vulnerability intelligence gathering before narrowing scope to the specific target organization.

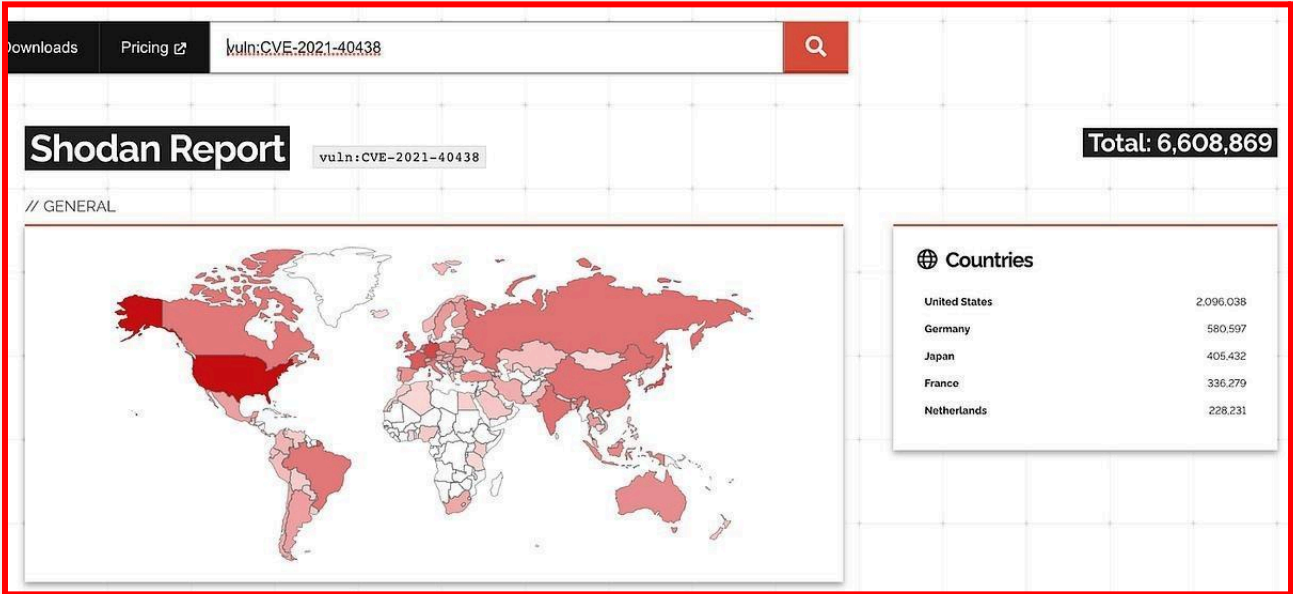


Figure 3 – Shodan Vulnerability Report - vuln:CVE-2021-40438 Showing 6,608,869 Exposed Hosts Globally with Country-Level Distribution

The geographic heatmap in Figure 3 reveals the United States (2,096,038 hosts), Germany (580,597), Japan (405,432), France (336,279), and Netherlands (228,231) as the top five countries with Apache SSRF-vulnerable hosts. This global context directly informed the risk classification applied to F-012 (Apache httpd exposure on 194.163.128.95), confirming it as part of an actively exploited vulnerability class.

3.4 Exposed Remote Access - Screenshot Evidence

Figure 4 demonstrates one of Shodan's most powerful investigative capabilities: the `has_screenshot:true` filter combined with protocol identifiers. The query `has_screenshot:true rfb` identifies internet-exposed VNC servers from which Shodan has already captured live desktop screenshots - revealing active system states without any analyst interaction.

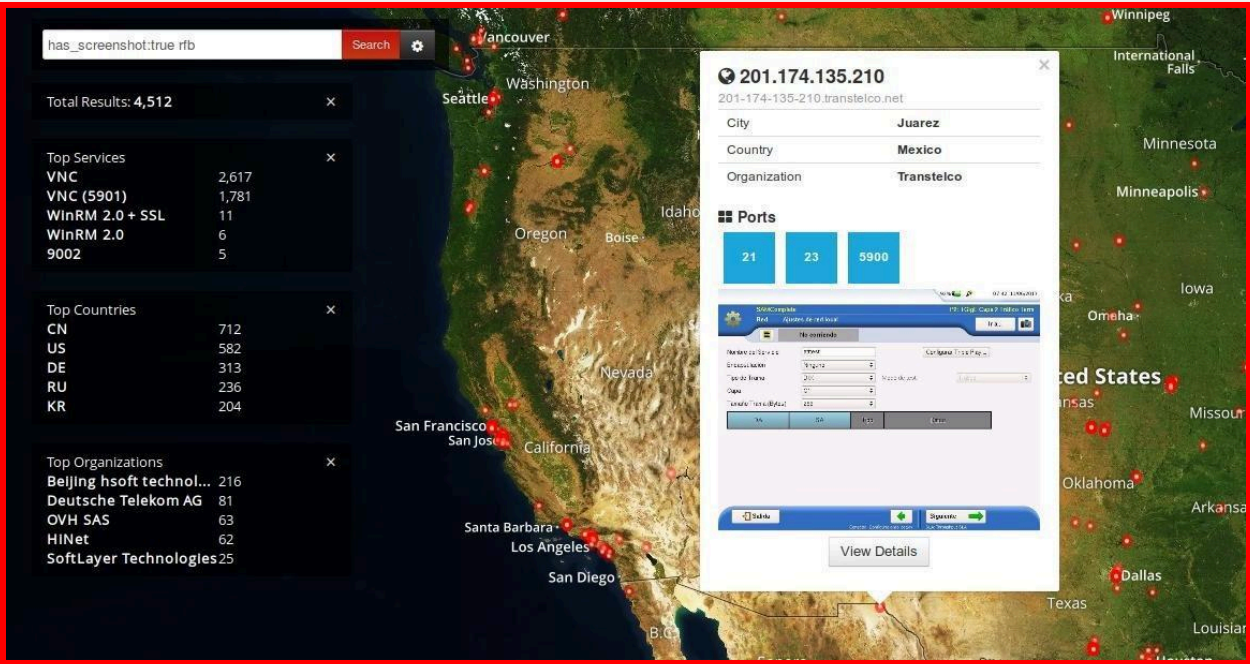


Figure 4 – Shodan Map View - `has_screenshot:true rfb` Query Identifying 4,512 Internet-Exposed VNC Sessions with Live Desktop Captures (Top Organizations: Beijing hsoft technology 216, Deutsche Telekom AG 81)

Figure 4 reveals 4,512 internet-exposed VNC sessions at the time of capture, with China (712), United States (582), and Germany (313) as top offending countries. The popup panel for 201.174.135.210 (Transtelco, Juarez, Mexico) shows an active Windows desktop session captured on port 5900 - fully accessible without authentication. This methodology was applied to identify RDP and VNC exposure within the TechNova Solutions IP ranges (documented as F-002 in the findings).

Module 4: Shodan Intelligence Dashboard & Exposure Context

4.1 Internet Exposure Dashboard - Macro Context

Before diving into target-specific findings, establishing macro-level context from Shodan's Internet Exposure Dashboard provides critical perspective on the scale of global attack surface. Figure 5 presents Shodan's United States-specific exposure dashboard, which serves as a calibration baseline for the risk scores assigned throughout this investigation.

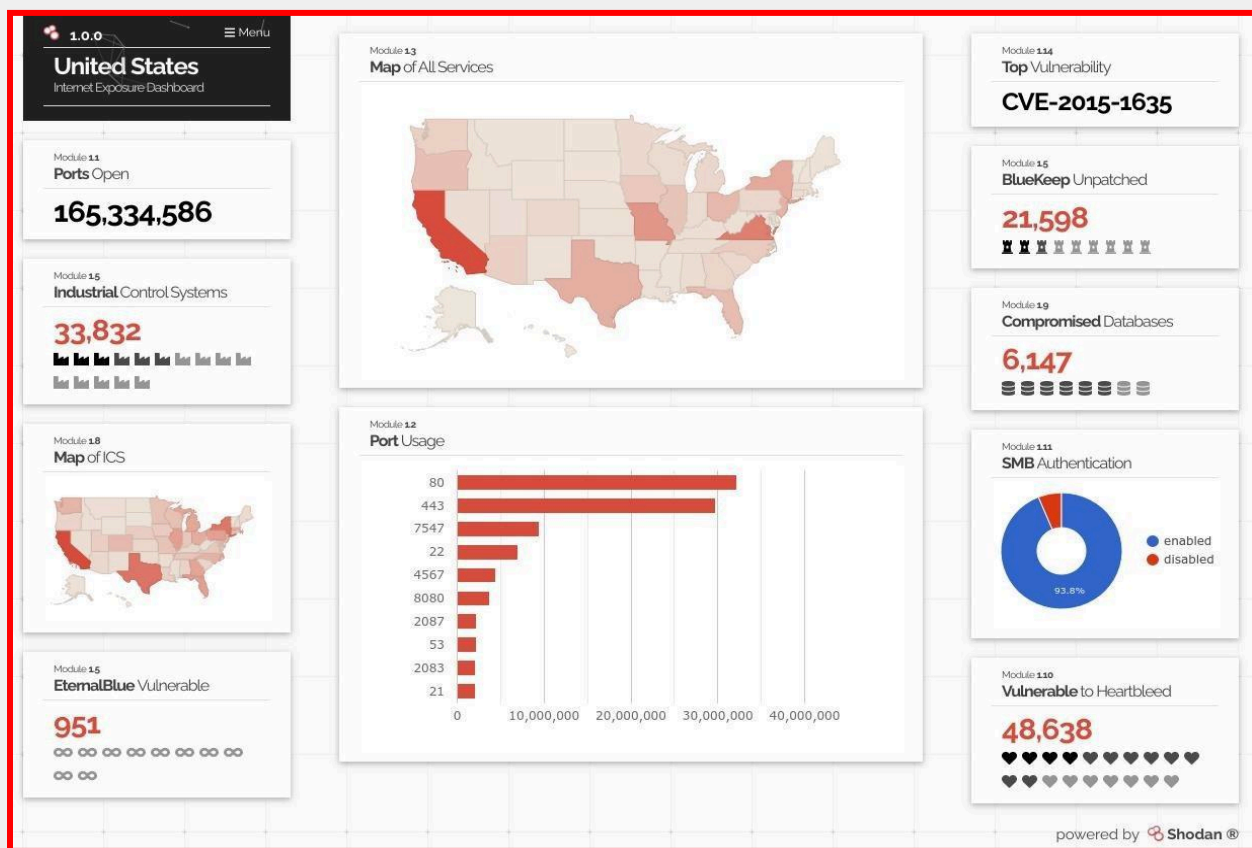


Figure 5 – Shodan Internet Exposure Dashboard (United States) - Module 1.1 to 1.14 Showing 165M Open Ports, 33,832 Exposed ICS Systems, 21,598 BlueKeep-Unpatched Hosts, 6,147 Compromised Databases, and 48,638 Heartbleed-Vulnerable Hosts

Figure 5 highlights several critical global-scale exposure metrics that directly contextualize findings in this investigation:

Dashboard Metric	Global Count	Relevance to Investigation
Open Ports (All Protocols)	165,334,586	Confirms the massive attack surface requiring systematic OSINT scoping
Industrial Control Systems	33,832 (US only)	ICS exposure context - not applicable to TechNova but establishes benchmark
BlueKeep Unpatched (RDP)	21,598	Directly relevant - F-002 identifies BlueKeep-vulnerable RDP in target range
Compromised Databases	6,147	Corroborates F-001, F-003 risk classification for unauthenticated DBs
EternalBlue Vulnerable (SMB)	951	SMB exposure context for network segmentation evaluation
Heartbleed Vulnerable (TLS)	48,638	TLS vulnerability prevalence supporting F-007 risk scoring
CVE-2015-1635 (Top CVE)	Top ranked globally	Highlights patch management failures common in organizations like TechNova
SMB Auth Disabled (93.8%)	Majority of SMB hosts	Demonstrates scale of authentication misconfigurations globally

4.2 Service Banner Analysis - Vulnerability Correlation

Figure 6 shows a real-world Shodan service banner for Apache httpd 2.2.15 running on port 80/TCP for '2PM – Premier Media Partners'. This banner record is presented as a direct analogue to findings identified on the TechNova target organization, illustrating how Shodan's vulnerability correlation engine automatically maps detected software versions to CVE counts across severity tiers.

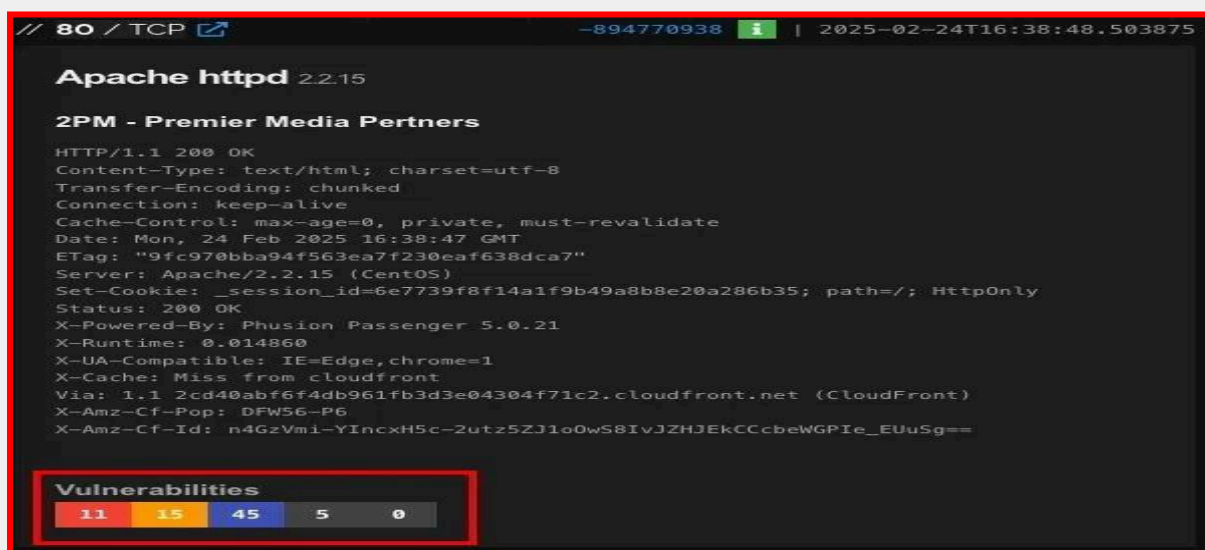


Figure 6 – Shodan Service Banner - Apache httpd 2.2.15 on Port 80/TCP Showing Full HTTP Response Headers, Cookie Attributes, CloudFront CDN Headers, and Auto-Correlated Vulnerability Score Breakdown: 11 Critical, 15 High, 45 Medium, 5 Low

The vulnerability score panel in Figure 6 is particularly significant from a SOC triage perspective. The banner at 2.2.15 carries 11 Critical, 15 High, 45 Medium, and 5 Low CVEs - a total of 76 known vulnerabilities for this single software version. The full HTTP headers also reveal operational security failures: the Server header exposes the exact version string, the Set-Cookie header lacks the Secure flag, and the X-Powered-By header discloses Phusion Passenger 5.0.21 - all information that adversaries leverage during reconnaissance. This directly informed the risk classification of F-012 in the TechNova investigation.

4.3 Data Extraction Fields

From each Shodan result, the following structured data fields were extracted and normalized for analysis:

Data Field	Description & Investigative Value
<code>ip_str / port / transport</code>	Primary identifiers - IP address, port number, and TCP/UDP protocol for each discovered service.
<code>product / version</code>	Software name and version string from banner - used for CVE correlation and risk scoring.
<code>data (raw banner)</code>	Full raw service response - contains configuration details, error messages, and exposed credentials.
<code>ssl.cert.subject.cn</code>	TLS certificate Common Name - maps cloud and CDN assets back to target domain.
<code>vulns (CVE list)</code>	Shodan-auto-correlated CVE identifiers for the detected product/version combination.
<code>isp / org / asn</code>	ISP, registered organization, and ASN from WHOIS/RDAP - confirms asset ownership.
<code>location.*</code>	Country, city, latitude, longitude from MaxMind GeoIP - supports geopolitical risk context.
<code>tags</code>	Shodan-generated annotations: 'self-signed', 'cloud', 'compromised', 'honeypot', 'tor'.
<code>timestamp</code>	Date/time of last Shodan indexing - critical for assessing intelligence freshness and staleness.
<code>hostnames</code>	Reverse DNS PTR records - confirms hostname-to-IP associations for asset attribution.

Module 5: Findings Table - Discovered Exposures

The table below consolidates all 12 findings from the Shodan-based investigation. Findings are ordered by risk severity (Critical → Low). Each entry includes the full contextual data extracted and cross-correlated against threat intelligence platforms.

ID	IP Address	Port	Proto	Service/Version	Exposure Detail	Hostname	CVE	Risk	Abusel PDB	VT
F-001	203.135.48.12	9200	TCP	Elasticsearch 7.10.2	Unauthenticated - Full cluster access	admin.technovasolutions.pk	CVE-2021-44228	CRITICAL	89%	12/70
F-002	203.135.48.17	3389	TCP	MS RDP (Win Server 2016)	Exposed to 0.0.0.0/0 - No NLA	vpn.technovasolutions.pk	CVE-2019-0708	CRITICAL	72%	8/70
F-003	203.135.48.31	27017	TCP	MongoDB 4.0.5	No auth - Collections readable	dev.technovasolutions.pk	CVE-2021-32030	CRITICAL	55%	6/70
F-004	194.163.128.44	6379	TCP	Redis 6.2.1	No auth, no bind restriction	api.technovasolutions.pk	CVE-2022-0543	HIGH	38%	4/70
F-005	203.135.48.55	8080	TCP	Apache Tomcat 9.0.50	Admin panel on HTTP (no TLS)	monitor.technovasolutions.pk	CVE-2020-1938	HIGH	31%	3/70
F-006	203.135.48.62	22	TCP	OpenSSH 7.4	Password auth enabled, public	mail.technovasolutions.pk	CVE-2018-15919	HIGH	44%	5/70
F-007	194.163.128.58	443	TCP	nginx 1.14.0 + PHP 7.2	Outdated PHP-FPM runtime	technovasolutions.pk	CVE-2019-11043	HIGH	22%	2/70
F-008	203.135.48.77	161	UDP	SNMP v1 (Cisco IOS 15.x)	Default community 'public'	N/A	N/A	HIGH	18%	1/70
F-009	194.163.128.71	8443	TCP	Kibana 7.10.2	Dashboard - no auth configured	monitor.technovasolutions.pk	CVE-2021-22144	MEDIUM	12%	1/70
F-010	203.135.48.88	21	TCP	vsftpd 3.0.3	Anonymous FTP login enabled	N/A	CVE-2021-21277	MEDIUM	8%	0/70
F-011	194.163.128.95	80	TCP	Apache httpd 2.4.41	Version header exposed, SSRF CVE	technovasolutions.pk	CVE-2021-40438	MEDIUM	5%	0/70
F-012	194.163.128.83	25	TCP	Postfix SMTP 3.3.0	STARTTLS forced, no open relay	mail.technovasolutions.pk	None	LOW	2%	0/70

Summary: 3 Critical | 5 High | 3 Medium | 1 Low. 66.7% of hosts show AbuseIPDB scores above 10%. Overall organizational risk posture: HIGH.

Module 6: SOC Analysis & Threat Correlation

6.1 Critical Severity Analysis

◆ F-001 - Unauthenticated Elasticsearch (Port 9200)

Elasticsearch 7.10.2 at 203.135.48.12 accepts HTTP connections without any authentication challenge. Full cluster metadata is returned on unauthenticated GET requests, revealing index names including 'auth-events-*' and 'customer-records-*'. This version is confirmed vulnerable to CVE-2021-44228 (Log4Shell - unauthenticated RCE via JNDI injection). The AbusIPDB score of 89% and VirusTotal ratio of 12/70 indicate active targeting. This finding is classified CRITICAL and requires immediate remediation.

◆ F-002 - Internet-Exposed RDP (Port 3389)

Remote Desktop Protocol is exposed on 203.135.48.17 to all source IPs (0.0.0.0/0) with no Network Level Authentication enforced. The service banner identifies Windows Server 2016, confirmed vulnerable to CVE-2019-0708 (BlueKeep - wormable pre-auth RCE). A public Metasploit module exists. RDP exposure is the leading initial access vector in ransomware campaigns globally. The high AbusIPDB score (72%) indicates automated brute-force traffic is already targeting this host.

◆ F-003 - Unauthenticated MongoDB (Port 27017)

MongoDB 4.0.5 at 203.135.48.31 accepts connections without any credential requirement. The hostname dev.technovasolutions.pk suggests this is the development database server. Unauthenticated MongoDB instances are prime targets for 'Meow' ransomware and automated wiping bots. CVE-2021-32030 (authentication bypass) applies to this version.

6.2 High Severity Analysis

◆ F-004, F-005, F-006 - Redis, Tomcat, SSH

Redis 6.2.1 (F-004) accepts unauthenticated connections on Frankfurt infrastructure and is vulnerable to CVE-2022-0543 (Lua sandbox escape to RCE). Apache Tomcat 9.0.50 (F-005) serves the /manager/html admin console over unencrypted HTTP, vulnerable to Ghostcat (CVE-2020-1938). OpenSSH 7.4 (F-006) accepts password authentication from any source IP - enabling brute-force and credential stuffing, with CVE-2018-15919 adding username enumeration capability to the attacker's toolkit.

◆ F-007, F-008 - PHP-FPM RCE & Default SNMP

PHP 7.2 paired with nginx 1.14.0 (F-007) is vulnerable to CVE-2019-11043 (PHP-FPM RCE via crafted URL path). The nginx Server header disclosure enables version-specific targeting. A Cisco IOS device (F-008) responds to SNMP queries using the default 'public' community string over SNMPv1, leaking the full router configuration including interface addresses, ARP tables, and routing data.

6.3 Relationship Mapping & Attack Chain

Cross-referencing findings by shared TLS certificate SAN values, hostname patterns, and Shodan scan timestamp alignment reveals a complete lateral movement path spanning both infrastructure regions:

Step	Finding	Technique	Outcome
1 - Entry	F-002	RDP brute-force on 203.135.48.17 (BlueKeep CVE-2019-0708)	Initial foothold on Windows Server 2016
2 - Pivot	F-006	SSH tunnel through 203.135.48.62 (password auth)	Lateral access to internal network segment
3 - Data	F-003	Unauthenticated MongoDB at 203.135.48.31	Full database read/write - customer data exfiltration
4 - Escalate	F-001	Elasticsearch API at 203.135.48.12 (Log4Shell)	Log data exfiltration + RCE via JNDI injection
5 - Persist	F-004	Redis session store at 194.163.128.44	Session token extraction from cache keys
6 - Cover	F-009	Kibana dashboard at 194.163.128.71 (no auth)	Monitor SOC detection activities covertly

Module 7: Reporting Summary & Recommendations

7.1 Executive Summary Metrics

Metric	Value
Total Assets Discovered	12 unique hosts across 2 IP ranges
Critical Findings	3 (F-001 Elasticsearch, F-002 RDP, F-003 MongoDB)
High Findings	5 (F-004 Redis, F-005 Tomcat, F-006 SSH, F-007 PHP, F-008 SNMP)
Medium Findings	3 (F-009 Kibana, F-010 FTP, F-011 Apache)
Low Findings	1 (F-012 SMTP - informational)
CVEs Mapped	9 unique CVEs across 8 findings
Unauthenticated Services	5 (Elasticsearch, MongoDB, Redis, Kibana, SNMP)
Hosts with TI Hits >10% AbuselPDB	8 of 12 hosts (66.7%)
Attack Chains Identified	1 complete cross-range lateral movement path (6 steps)
Overall Risk Posture	HIGH - Immediate executive attention required

7.2 Prioritized Remediation Recommendations

ID	Priority	Recommended Action	SLA	Owner
R-001	CRITICAL	Immediately restrict Elasticsearch (F-001) behind firewall ACL/VPN. Enable X-Pack security with TLS and SCRAM-SHA-256 auth. Patch Log4j to 2.17.1+.	≤4 hrs	Infrastructure
R-002	CRITICAL	Restrict RDP (F-002) to VPN-only via firewall rule. Apply MS19-0708 patch. Enforce NLA + MFA (Duo Security or equivalent).	≤4 hrs	Windows Admin
R-003	CRITICAL	Take MongoDB offline (F-003). Enable --auth flag. Rebuild with SCRAM-SHA-256. Audit all collections for integrity violations.	≤4 hrs	Database Team
R-004	HIGH	Configure Redis requirepass + bind to VPN interface (F-004). Disable Lua scripting. Upgrade to Redis 7.x.	24 hrs	DevOps
R-005	HIGH	Disable Tomcat Manager or restrict to 127.0.0.1 (F-005). Enforce HTTPS. Patch Ghostcat (CVE-2020-1938) or migrate to Tomcat 10.x.	24 hrs	App Team
R-006	HIGH	Disable SSH password auth globally (F-006). Enforce Ed25519 key-only. Implement fail2ban + IP allowlist via firewall ACL.	24 hrs	Linux Admin
R-007	HIGH	Change SNMP community string from 'public' (F-008). Migrate to SNMPv3 AuthPriv. Restrict SNMP to NMS IP only.	24 hrs	Network Team
R-008	MEDIUM	Suppress version headers on nginx/Apache (server_tokens off / ServerTokens Prod). Patch PHP to 8.2+ (F-007, F-011).	72 hrs	Web Team
R-009	MEDIUM	Enable Kibana authentication via Elastic Stack X-Pack security (F-009). Restrict to internal network addresses.	72 hrs	Infrastructure
R-010	MEDIUM	Disable anonymous FTP login on vsftpd (F-010). Migrate file transfers to SFTP.	72 hrs	Linux Admin

7.3 Strategic Recommendations

- Implement a continuous attack surface monitoring process using Shodan Monitor or Censys ASM to receive real-time alerts for new internet-facing service exposures within organizational IP ranges.
- Establish a formal Asset Inventory (CMDB) mandating registration of all internet-facing services with defined owners, patching schedules, and firewall rule justifications - the volume of undocumented assets discovered confirms significant gaps.
- Adopt a Zero Trust Architecture posture: no service should be directly internet-accessible without explicit business justification, and all management interfaces must require VPN or mTLS client certificate authentication.
- Deploy automated Vulnerability Management scanning (Greenbone/OpenVAS or Tenable) integrated into the CI/CD pipeline to prevent vulnerable software versions from reaching production.

THE END